REQUIREMENTS SPECIFICATION

Client Requirements Document

Enterprise PDF & Digital Asset Vault Platform

Project Name	PDF-Storage-System (PDF Vault)	**Document ID**	CRD-PDFV-2026-V1
Version	1.0.0 (Final)	**Date of Release**	October 20, 2026
Prepared By	Enterprise Solution Engineering	**Client Sponsor**	Executive Product Steering Committee
Classification	Confidential / Commercial in Confidence	**Target Environment**	Production / Multi-Tenant Cloud

1. Document Control & Revision History

This document formalizes the complete business and technical requirements for the PDF Vault & Digital Asset Storage System. Any revisions must be approved via the change control board.

Version	Date	Author	Change Summary	Approval Status
v0.1	2026-09-15	Lead Systems Analyst	Initial draft of document ingestion & storage	Draft
v0.5	2026-10-02	Senior Software Architect	Added Scrypt/JWT authentication & Image Studio	Reviewed
v1.0	2026-10-20	Enterprise Solution Architect	Final baseline for client sign-off & implementation	Approved

2. Executive Summary & Purpose

Modern enterprises and professionals face significant friction managing sensitive documents, contracts, invoices, and digital marketing assets across fragmented cloud drives and local storage. Standard consumer storage solutions frequently lack strict format validation, granular multi-tenant isolation, real-time quota telemetry, and categorized asset workspaces.

The PDF Vault platform is an enterprise-grade web application engineered to provide high-speed, secure, and authenticated storage, organization, and retrieval for PDF documents and digital image assets. The system couples a high-performance Python FastAPI backend with an intuitive React 18 Single Page Application (SPA), guaranteeing sub-second response times, end-to-end data segregation, and flexible tiered usage governance.

> **Primary System Objective**
>
> To deliver a secure, multi-tenant digital vault that prevents unauthorized file execution through binary magic-byte verification, organizes assets into logical folders and categories, provides real-time search, and enforces usage quotas under Free and Pro tier plans.

3. Stakeholder Profiles & User Personas

The application serves distinct user cohorts across the document lifecycle:

Persona / Role	Primary Responsibilities	Core Needs & Pain Points	Key System Touchpoints
Knowledge Worker / Professional	Uploads invoices, reports, and contracts daily; organizes files by project.	Needs fast upload with drag-and-drop, instantaneous search, and reliable download without naming conflicts.	Dashboard, Folder Navigation, Document Upload Panel, Search Bar
Marketing / Content Specialist	Manages brand assets, banners, screenshots, and visual media files.	Requires visual gallery with categorized grouping, image thumbnail previews, and instant deletion.	Image Workspace, Category Management Studio, Image Viewer

Persona / Role	Primary Responsibilities	Core Needs & Pain Points	Key System Touchpoints
Organizational Administrator	Monitors storage footprint, manages quota consumption, handles tier upgrades.	Needs visibility into total bytes stored, daily upload limit notifications, and seamless Pro plan activation.	Storage Gauge Metrics, Plans Comparison Page, Account Profile Modal
Security & Compliance Officer	Ensures tenant data privacy, zero-trust file validation, and auditability.	Strict validation that files are genuine PDFs (no masquerading executables), passwords hashed securely, zero cross-user leakage.	Scrypt Auth Service, Magic Header Validator, User-scoped DB Queries

4. Functional Requirements (FR) Specification

Requirements are categorized by functional module and prioritized according to the MoSCoW methodology (Must Have, Should Have, Could Have, Won't Have).

4.1 Module 1: Identity & Access Management (IAM)

- **FR-AUTH-01 (Must Have):** User Registration: System must allow new users to register with a unique username (min 3 chars), unique email address, and a strong password (min 8 chars). Duplicate usernames or emails must return HTTP 409 Conflict.
- **FR-AUTH-02 (Must Have):** Scrypt Password Hashing: All user passwords must be hashed using the memory-hard scrypt algorithm with dynamic cryptographic salts (N=16384, r=8, p=1, dklen=64). Raw passwords must never be logged or persisted.
- **FR-AUTH-03 (Must Have):** OAuth2 & JWT Token Generation: System must authenticate users via email and password using OAuth2 Password Bearer flow, issuing a cryptographically signed HMAC-SHA256 JWT token with configurable lifespan (default 60 minutes).
- **FR-AUTH-04 (Must Have):** Stateless Session Verification: Protected endpoints must extract and validate the Bearer token, verify expiration timestamps, and inject the authenticated User context (`get_current_user`).
- **FR-AUTH-05 (Should Have):** Current User Profile (`/auth/me`): Authenticated clients must be able to query their user identifier, username, and email to populate client session states.

4.2 Module 2: Folder & Taxonomy Management

- **FR-FOLD-01 (Must Have):** Folder Creation: Users must be able to create named folders (up to 120 characters) within their private tenant scope. Duplicate folder names per user must return HTTP 409.
- **FR-FOLD-02 (Must Have):** Folder Listing: System must list all folders owned by the active user in alphabetical order, returning folder UUIDs and names.
- **FR-FOLD-03 (Must Have):** Safe Folder Deletion: Deleting a folder must safely un-categorize contained documents by setting `folder_id` to NULL without deleting the actual PDF files or their physical storage payloads.

4.3 Module 3: PDF Document Vault & Processing

- **FR-DOC-01 (Must Have):** Binary File Signature Validation: System must inspect the initial 5 bytes of every uploaded file to verify the true magic header `b'%PDF-'`. Any file without this exact signature must be rejected immediately with HTTP 415 Unsupported Media Type.
- **FR-DOC-02 (Must Have):** Streaming Chunked Ingestion: Upload processing must read the input stream in 1MB chunks to prevent memory spikes on large files.
- **FR-DOC-03 (Must Have):** File Size Enforcement: System must enforce a strict maximum file size limit (default 25MB, configurable via `.env`). Exceeding files must abort upload with HTTP 413 Payload Too Large and trigger automatic disk cleanup.
- **FR-DOC-04 (Must Have):** Cryptographic Storage Naming: Files stored on the filesystem must use randomized UUID4 hex identifiers (`<uuid4>.pdf`) to completely mitigate path traversal and namespace collisions while preserving the original user filename in metadata.
- **FR-DOC-05 (Must Have):** Filtered Document Search: Users must be able to query documents filtered by folder assignment and case-insensitive filename substring matching (`ilike`).
- **FR-DOC-06 (Must Have):** Binary Download: System must serve documents with exact binary streams and proper HTTP response headers (`application/pdf`, `Content-Disposition`) preserving the original uploaded filename.
- **FR-DOC-07 (Must Have):** Atomic Deletion: Deleting a document must delete both the database record and physically unlink the stored file from disk. If the database transaction fails, disk operations must remain consistent.

4.4 Module 4: Digital Image Asset Studio

- **FR-IMG-01 (Must Have):** Image Category Isolation: System must provide separate categorization hierarchies for images, distinct from document folders.
- **FR-IMG-02 (Must Have):** Supported Format Validation: Only approved MIME types (`image/jpeg`, `image/png`, `image/gif`, `image/webp`, `image/bmp`) and file extensions (`.jpg`, `.jpeg`, `.png`, `.gif`, `.webp`, `.bmp`) shall be accepted.

- **FR-IMG-03 (Must Have):** Direct Binary File Streaming: The API must serve image binaries directly to the frontend for client-side blob rendering and image previewing.
- **FR-IMG-04 (Must Have):** Category Cascading Deletion: Deleting an image category must atomically remove all associated image assets from both database and physical filesystem storage.

4.5 Module 5: Subscription Governance & Quota Enforcement

- **FR-PLAN-01 (Must Have):** Tier Definitions: The system must support two tiers: Starter (Free) and Pro ($9/month).
- **FR-PLAN-02 (Must Have):** Daily Upload Rate Limiting: Free tier users must be capped at 3 PDF uploads per day and 5 image uploads per day. Attempted uploads beyond this quota must block execution and present the Pro upgrade modal.
- **FR-PLAN-03 (Must Have):** Real-Time Quota Telemetry: The client application must track daily usage metrics against local session keys (`pdf_vault_free_uploads_{user_id}_{date}`) and display real-time storage metrics.

5. Non-Functional Requirements (NFR) Specification

Non-functional specifications establish technical quality attributes, resilience standards, and governance rules:

Category	Parameter / Metric	Acceptance Benchmark	Implementation Architecture
Performance	Metadata Query Latency	< 100 ms at 95th percentile	Indexed SQLAlchemy queries on `user_id`, `filename`, `folder_id`.
Performance	File Upload Throughput	Streaming 1 MB buffer chunks	FastAPI async stream reading, direct disk write without buffering entire file in RAM.
Security	Tenant Data Isolation	100% User Segregation	Mandatory `user_id` filtering in all ORM queries; no shared global tables without tenancy key.
Security	Credential Protection	Memory-hard password hashing	Scrypt key derivation function (N=16384, r=8, p=1); HMAC timing-safe comparison.

Category	Parameter / Metric	Acceptance Benchmark	Implementation Architecture
Security	File Upload Protection	Zero executable masquerading	Magic byte header inspection (`%PDF-`), UUID4 disk naming preventing directory traversal.
Reliability	Transactional Rollback	Zero orphaned disk files	Try-except block on disk writes: if database commit fails, `target.unlink(missing_ok=True)`.
Usability	Cross-Browser Compatibility	Full functionality across modern browsers	Vite 6 build target supporting Chrome, Safari, Firefox, Edge on desktop and mobile viewports.

6. Acceptance Criteria & Quality Sign-Off

The client acceptance phase requires full verification of the following formal test conditions:

- **AC-01:** A user can register with valid credentials and immediately authenticate without error.
- **AC-02:** Uploading a non-PDF file renamed with a `.pdf` extension is rejected with HTTP 415 and the file is deleted from disk.
- **AC-03:** A 24MB valid PDF uploads successfully and is downloadable with its original filename intact.
- **AC-04:** Free tier users attempting a 4th PDF upload in a calendar day are blocked with an upgrade prompt.
- **AC-05:** Deleting a folder preserves all PDFs previously assigned to it, transitioning them to 'uncategorized'.
- **AC-06:** All API routes reject unauthenticated requests with HTTP 401 Unauthorized.

7. Client Approval & Sign-Off Matrix

By signing below, the authorized client stakeholders confirm that this requirements document represents the agreed-upon functional and technical baseline for system acceptance.

Stakeholder Role	Name	Designation / Title	Signature	Date
Client Executive Sponsor	_____	Chief Technology Officer	_____	___/___/2026
Client Product Lead	_____	Head of Product	_____	___/___/2026
Technical Delivery Lead	Enterprise Arch Team	Solutions Architect	_____	___/___/2026
QA & Compliance Lead	Quality Assurance	Lead QA Engineer	_____	___/___/2026